

500 Advanced IT Interview Questions

*SOC • Network+ • CCNA • CEH • LPIC-1 | Scenario-Based,
Troubleshooting & Interview Focused*

How to use this document

- Answer each scenario before checking the answer key.
- Use the structure: Symptom → Hypothesis → Evidence/Tool → Fix → Verification.
- Explain your reasoning, not just the command or definition.
- Practice weak areas in a lab and be ready to explain your troubleshooting decisions.

Network+

100 Questions

OSI & TCP/IP

1. What is the OSI model and why is it useful?
2. How would you compare the OSI model with the TCP/IP model?
3. At which OSI layer does logical addressing operate?
4. At which OSI layer does MAC addressing operate?
5. What is a PDU?
6. Which OSI layer is responsible for reliable end-to-end delivery?
7. What is encapsulation?
8. Why is the OSI model valuable during troubleshooting?
9. Give an example of a Layer 1 problem.
10. Give an example of a Layer 3 problem.

Subnetting

11. How many usable IPv4 hosts are available in a /24 network?
12. How many usable hosts are available in a /26?
13. What is the network address of 192.168.10.70/26?
14. What is the broadcast address of 192.168.10.70/26?
15. What prefix provides at least 14 usable hosts per subnet?
16. What prefix provides at least 30 usable hosts?
17. What is VLSM?
18. Why is VLSM useful?
19. What is CIDR?
20. What is the fastest way to solve subnetting questions in an interview?

Routing

21. What is routing?
22. What is a routing table?
23. What is longest prefix match?

24. What is a default route?
25. What is a next hop?
26. What is administrative distance?
27. What is a routing metric?
28. What is the difference between static and dynamic routing?
29. Why can a ping fail even when the forward route exists?
30. Which commands are useful for basic routing troubleshooting?

DNS & DHCP

31. What is DNS?
32. What does an A record do?
33. What does an AAAA record do?
34. What is a CNAME record?
35. What is DHCP?
36. What is the DHCP DORA process?
37. Why is DHCP relay needed across routers?
38. What does nslookup help you test?
39. What does dig provide on Linux?
40. A user can ping an IP but not a hostname. What should you check first?

TCP & UDP

41. What is the main difference between TCP and UDP?
42. What is the TCP three-way handshake?
43. What does TCP use sequence numbers for?
44. What is an ACK?
45. Why is UDP common for real-time applications?
46. What is a TCP port?
47. What does a closed TCP port usually indicate?
48. What does a filtered port mean in scanning context?
49. Which tools help analyze TCP problems?

50. How can packet loss affect TCP?

Switching

51. What does a switch use a MAC address table for?

52. How does a switch learn MAC addresses?

53. What happens to an unknown unicast frame?

54. What is a broadcast domain?

55. What is a collision domain on a modern switched network?

56. What is MAC flapping?

57. What can cause a broadcast storm?

58. What is a trunk port?

59. What is an access port?

60. Which Cisco commands help troubleshoot switching?

Wireless

61. What are the common non-overlapping 2.4 GHz Wi-Fi channels in many regulatory domains?

62. What is co-channel interference?

63. What is adjacent-channel interference?

64. What is the difference between authentication and encryption?

65. Why is WEP considered insecure?

66. What is WPA2-Personal commonly based on?

67. What is WPA3-Personal designed to improve?

68. Why can a Wi-Fi client have a strong signal but poor performance?

69. What should you check if clients associate but cannot get an IP address?

70. What is an omnidirectional antenna?

NAT & ACL

71. What is NAT?

72. What is PAT?

73. What is static NAT?

74. Why is PAT common in IPv4 networks?
75. What is an ACL?
76. Why does ACL rule order matter?
77. What is the implicit deny concept?
78. Why can ping work while an application fails?
79. What should you verify when NAT is not working?
80. Is NAT a replacement for a firewall?

STP

81. What problem does STP solve?
82. What is the STP root bridge?
83. How is the root bridge selected?
84. What is a root port?
85. What is a designated port?
86. What is BPDU?
87. What is PortFast used for?
88. Why should PortFast not normally be used on switch-to-switch links?
89. What is BPDU Guard?
90. How would you troubleshoot an unexpected STP block?

Network Troubleshooting

91. What is a good general troubleshooting methodology?
92. Why should you avoid random configuration changes?
93. What does ping test?
94. What does traceroute help identify?
95. What does ipconfig/ifconfig/ip help you verify?
96. What is packet capture useful for?
97. What should you check first when a host has no network access?
98. A service is reachable by IP but not by name. What layer or service should you investigate?

99. A host can reach its gateway but not remote networks. What should you investigate?
100. How do you prove a fix worked?

Answer Key — Network+

OSI & TCP/IP

1. It is a seven-layer reference model used to understand network functions and troubleshoot problems layer by layer.
2. OSI is a seven-layer reference model; TCP/IP is a practical protocol architecture used by modern networks and commonly represented with four or five layers.
3. Layer 3, the Network layer.
4. Layer 2, the Data Link layer.
5. A Protocol Data Unit is the unit of data handled at a specific protocol layer, such as a frame at Layer 2 and a packet at Layer 3.
6. The Transport layer, especially TCP.
7. It is the process of adding protocol headers, and sometimes trailers, as data moves down the protocol stack.
8. It gives a structured way to isolate faults instead of changing multiple things randomly.
9. A damaged cable, failed transceiver, or loss of electrical/optical signal.
10. An incorrect IP address, subnet mask, route, or default gateway.

Subnetting

11. 254 usable host addresses.

12. 62 usable hosts.

13. 192.168.10.64.

14. 192.168.10.127.

15. /28, which provides 14 usable hosts.

16. /27.

17. Variable Length Subnet Masking allows different subnet sizes to be used according to actual requirements.

18. It reduces address waste and lets administrators allocate appropriately sized networks.

19. Classless Inter-Domain Routing represents networks with prefix lengths rather than traditional classful boundaries.

20. Identify the required hosts or subnets, calculate the needed borrowed bits, determine the block size, then find network and broadcast ranges.

Routing

21. Routing is the process of selecting a path and forwarding IP packets toward a destination network.

22. A database of known destination networks, next hops, interfaces, metrics, and route sources.

23. The router selects the most specific matching route, meaning the route with the longest prefix length.

24. A route used when no more specific route matches the destination, commonly 0.0.0.0/0.

25. The next Layer 3 device or reachable address to which a packet is forwarded.

- 26.** A Cisco value used to rank routes learned from different sources; lower values are preferred.
- 27.** A value used by a routing protocol to compare paths within that protocol.
- 28.** Static routes are manually configured; dynamic routing protocols learn and update routes automatically.
- 29.** The destination may lack a return route, or ACLs, firewalls, NAT, or the endpoint itself may block the traffic.
- 30.** show ip route, show ip interface brief, ping, traceroute, and protocol-specific show commands.

DNS & DHCP

- 31.** DNS translates names such as server.example.com into IP addresses and can also provide other records.
- 32.** It maps a hostname to an IPv4 address.
- 33.** It maps a hostname to an IPv6 address.
- 34.** It creates an alias that points one hostname to another canonical hostname.
- 35.** Dynamic Host Configuration Protocol automatically provides IP configuration such as address, mask, gateway, and DNS servers.
- 36.** Discover, Offer, Request, and Acknowledge.
- 37.** Routers normally do not forward DHCP broadcasts, so a relay forwards the client request to a DHCP server.
- 38.** DNS name resolution and responses from a DNS server.

39. Detailed DNS query and response information useful for troubleshooting.

40. Check DNS server configuration, name resolution, and whether the DNS server is reachable.

TCP & UDP

41. TCP provides connection-oriented, reliable delivery; UDP is connectionless with lower overhead.

42. SYN, SYN-ACK, and ACK.

43. They help order bytes and support reliable delivery and retransmission.

44. An acknowledgment indicating that data has been received as expected.

45. It avoids TCP connection and retransmission overhead, reducing latency when some packet loss is acceptable.

46. A logical endpoint identifier used to distinguish application services on a host.

47. The host is reachable but no application is listening on that port, or the host actively rejected the connection.

48. A filtering device prevents the scanner from determining whether the port is open or closed.

49. Packet captures with Wireshark/tcpdump, ss/netstat, ping, traceroute, and application logs.

50. It can cause retransmissions, increased latency, reduced throughput, and congestion-control behavior.

Switching

- 51.** It maps learned MAC addresses to switch ports so frames can be forwarded efficiently.
- 52.** It records the source MAC address of incoming frames and associates it with the ingress port.
- 53.** The switch floods it within the VLAN except through the incoming port.
- 54.** A Layer 2 area in which broadcast frames are propagated.
- 55.** Typically each switch port is its own collision domain.
- 56.** A switch repeatedly learns the same MAC address on different ports, often indicating a loop or topology problem.
- 57.** Layer 2 loops, excessive broadcasts, or misconfigured devices.
- 58.** A link that carries traffic for multiple VLANs using VLAN tagging.
- 59.** A switch port assigned to one VLAN for an endpoint such as a PC.
- 60.** show mac address-table, show interfaces status, show interfaces counters, show vlan brief, and show interfaces trunk.

Wireless

- 61.** Channels 1, 6, and 11 are the commonly used non-overlapping set in the 2.4 GHz band.
- 62.** Multiple nearby access points or clients use the same channel and must share airtime.
- 63.** Overlapping channel frequencies interfere with one another.
- 64.** Authentication determines who can connect; encryption protects data in transit.
- 65.** Its cryptographic design has serious weaknesses and it should not be used for modern secure networks.

- 66.** A pre-shared key with AES/CCMP in typical configurations.
- 67.** It improves wireless authentication security, including stronger password-based protection.
- 68.** Interference, congestion, retransmissions, channel utilization, client capability, or AP load may be responsible.
- 69.** SSID-to-VLAN mapping, DHCP, VLAN configuration, AP uplink, relay, and gateway settings.
- 70.** An antenna designed to radiate approximately around the horizontal plane rather than focusing energy in one direction.

NAT & ACL

- 71.** Network Address Translation changes source or destination IP addressing as traffic crosses a translation boundary.
- 72.** Port Address Translation allows many internal sessions to share one public IPv4 address by using different source ports.
- 73.** A fixed one-to-one mapping between an inside address and a translated address.
- 74.** It conserves public IPv4 addresses by allowing many private hosts to share a public address.
- 75.** An Access Control List is an ordered set of rules used to permit or deny traffic.
- 76.** Rules are evaluated in order and the first matching rule is applied.
- 77.** Traffic that does not match a permit rule is denied at the end of an ACL.
- 78.** ICMP and application traffic are different protocols and ports; ACLs, firewalls, or the service itself may block the application.

79. Inside/outside interfaces, translation rules, ACL or match conditions, routing, and NAT translation entries.

80. No. NAT translates addresses; a firewall enforces security policy and may provide stateful inspection.

STP

81. It prevents Layer 2 switching loops while allowing redundant links.

82. The switch selected as the logical reference point for the spanning-tree topology.

83. The switch with the lowest Bridge ID is selected.

84. On a non-root switch, the port with the best path toward the root bridge.

85. The forwarding port selected for a segment toward the root.

86. Bridge Protocol Data Unit, used by STP to exchange topology information.

87. It lets an edge/access port transition quickly to forwarding for endpoint devices.

88. A topology link can create loops or bypass expected STP behavior.

89. A protection feature that can shut or err-disable an edge port if BPDUs are received.

90. Check the root bridge, port roles, path cost, BPDUs, topology changes, and recent Layer 2 changes.

Network Troubleshooting

91. Define the problem, gather evidence, form a hypothesis, test it, apply a controlled fix, and verify the result.

- 92.** They can hide the original problem, introduce new faults, and make the root cause harder to identify.
- 93.** Basic IP reachability and round-trip response, subject to ICMP filtering.
- 94.** The Layer 3 path and the hop where forwarding or response problems may occur.
- 95.** Local interface addressing, routes, and other host network configuration depending on the command.
- 96.** It provides direct evidence about protocols, flags, retransmissions, DNS, TCP handshakes, and application traffic.
- 97.** Physical/link state, interface configuration, IP address, mask, gateway, and local connectivity.
- 98.** DNS and name-resolution configuration.
- 99.** Routing, ACL/firewall policy, NAT, and the remote return path.
- 100.** Repeat the original failing test, test from another relevant point, and verify counters/logs or service health when possible.

CCNA

100 Questions

Cisco IOS & Interfaces

- 101. What are the main Cisco IOS command modes?
- 102. How do you enter privileged EXEC mode?
- 103. How do you enter global configuration mode?
- 104. How do you verify interface status and IP addresses?
- 105. How do you save the running configuration?
- 106. What does no shutdown do on an interface?
- 107. What does shutdown do?
- 108. What is the difference between running-config and startup-config?
- 109. What does show interfaces provide?
- 110. What is a common first step when an interface is down?

VLANs & Trunks

- 111. What is a VLAN?
- 112. What is an access port?
- 113. What is a trunk?
- 114. What is 802.1Q?
- 115. What is the native VLAN?
- 116. What happens if the native VLAN is mismatched?
- 117. How do you verify VLAN membership?
- 118. How do you verify trunk status?
- 119. Why can two hosts in different VLANs not communicate through a Layer 2 switch alone?
- 120. What should you check when a VLAN host cannot reach its gateway?

EtherChannel

- 121. What is EtherChannel?
- 122. Why use EtherChannel?

- 123. What is LACP?
- 124. What is PAgP?
- 125. What can prevent EtherChannel formation?
- 126. How do you verify EtherChannel?
- 127. What is a port-channel interface?
- 128. Should configuration be applied consistently to EtherChannel member ports?
- 129. What is a common symptom of a bad EtherChannel configuration?
- 130. How would you troubleshoot an EtherChannel?

OSPF

- 131. What is OSPF?
- 132. What algorithm does OSPF use?
- 133. What is an OSPF area?
- 134. What is Area 0?
- 135. What is an OSPF neighbor adjacency?
- 136. What can prevent OSPF neighbors from forming?
- 137. What is the OSPF router ID?
- 138. What is OSPF cost?
- 139. Which command verifies OSPF neighbors?
- 140. Which commands help troubleshoot OSPF routes?

Static & Default Routing

- 141. What is a static route?
- 142. What is a default static route?
- 143. What is a floating static route?
- 144. Why use a next-hop address in a static route?
- 145. Why might a static route not appear in the routing table?
- 146. What is recursive route lookup?
- 147. How do you verify static routes?
- 148. What is route summarization?

- 149. Why is a return route important?
- 150. How do you troubleshoot a routing failure?

HSRP & FHRP

- 151. What is HSRP?
- 152. What is FHRP?
- 153. What is the HSRP active router?
- 154. What is the standby router?
- 155. Why use a virtual IP?
- 156. How can HSRP preference be influenced?
- 157. What is preemption?
- 158. What should you check if HSRP does not form?
- 159. What command verifies HSRP?
- 160. What is a practical HSRP troubleshooting approach?

NAT & ACLs

- 161. How do you configure a basic Cisco standard ACL?
- 162. Where is a standard ACL commonly placed?
- 163. Where is an extended ACL commonly placed?
- 164. What is the implicit deny?
- 165. Why can an ACL appear correct but still break traffic?
- 166. How do you verify an ACL?
- 167. What does NAT overload mean?
- 168. How do you verify NAT translations?
- 169. What must be correct for Cisco NAT to work?
- 170. What is a good ACL troubleshooting method?

Layer 3 Switching

- 171. What is an SVI?
- 172. What is inter-VLAN routing on a multilayer switch?
- 173. What command enables IPv4 routing on many Cisco multilayer switches?

- 174. Why might an SVI be down/down?
- 175. What is a routed port?
- 176. How do you convert a switchport to a routed port?
- 177. What is the difference between an SVI and a routed port?
- 178. How do you verify SVI status?
- 179. What is a common inter-VLAN routing failure?
- 180. How would you troubleshoot a Layer 3 switch?

Cisco Security

- 181. Why should unused switch ports be secured?
- 182. What is port security?
- 183. What is DHCP snooping?
- 184. What is Dynamic ARP Inspection?
- 185. What is IP Source Guard?
- 186. What is BPDU Guard?
- 187. Why is SSH preferred over Telnet?
- 188. What is AAA?
- 189. What is a secure management practice for Cisco devices?
- 190. How would you explain defense in depth on a switch?

CCNA Troubleshooting

- 191. A PC has an IP address but cannot ping its gateway. What do you check?
- 192. A trunk is up but one VLAN cannot cross it. What do you check?
- 193. OSPF neighbors are stuck in EXSTART. What common issue should you investigate?
- 194. A static route is configured but traffic still fails. What do you verify?
- 195. HSRP is configured but both routers appear active. What might be wrong?
- 196. EtherChannel has one suspended member. What should you compare?

- 197. A VLAN host gets an APIPA address. What should you investigate?
- 198. An interface shows up/down. What does that suggest?
- 199. Which Cisco command is a strong first check for interface/IP status?
- 200. How should you answer a CCNA troubleshooting interview question?

Answer Key — CCNA

Cisco IOS & Interfaces

- 1. User EXEC, Privileged EXEC, Global Configuration, and sub-configuration modes such as interface configuration.
- 2. Use the enable command.
- 3. Use configure terminal from privileged EXEC mode.
- 4. Use show ip interface brief.
- 5. Use copy running-config startup-config.
- 6. It administratively enables the interface.
- 7. It administratively disables the interface.
- 8. Running-config is active in RAM; startup-config is the saved configuration used during boot.
- 9. Detailed Layer 1/2 statistics, errors, counters, and interface state.
- 10. Check the physical connection, interface status, speed/duplex, and configuration with show interfaces and show ip interface brief.

VLANs & Trunks

- 11. A logical Layer 2 segmentation mechanism that creates separate broadcast domains.
- 12. A port assigned to one VLAN, typically for an endpoint.

- 13.** A link that carries multiple VLANs using VLAN tags.
- 14.** The common VLAN tagging standard used on Ethernet trunks.
- 15.** The VLAN whose frames are sent untagged on an 802.1Q trunk.
- 16.** It can cause connectivity and security problems because untagged traffic is interpreted differently at each end.
- 17.** Use show vlan brief.
- 18.** Use show interfaces trunk.
- 19.** Each VLAN is a separate broadcast domain and requires Layer 3 routing to communicate.
- 20.** Access VLAN assignment, trunk allowed VLANs, SVI status, cabling, and the gateway configuration.

EtherChannel

- 21.** It bundles multiple physical links into one logical port-channel.
- 22.** It increases aggregate bandwidth and provides link redundancy while reducing STP complexity.
- 23.** Link Aggregation Control Protocol, an open standard for negotiating link aggregation.
- 24.** Cisco-proprietary Port Aggregation Protocol.
- 25.** Mismatched speed, duplex, VLAN/trunk settings, channel parameters, or incompatible negotiation modes.
- 26.** Use show etherchannel summary.
- 27.** The logical interface representing the bundled physical links.
- 28.** Yes; important Layer 2 or Layer 3 parameters must be compatible.

29. Some member links remain suspended or individual links fail to join the bundle.

30. Compare member configuration, negotiation mode, VLAN/trunk settings, physical state, and show etherchannel output.

OSPF

31. A link-state interior gateway routing protocol.

32. Dijkstra's Shortest Path First algorithm.

33. A logical grouping used to improve scalability and limit topology information.

34. The OSPF backbone area.

35. A relationship between OSPF routers that exchange routing information.

36. Incorrect area, timers, network type, authentication, MTU, passive-interface behavior, or Layer 3 reachability.

37. A unique identifier for the OSPF process, selected from configured or eligible addresses according to IOS rules.

38. The metric used to choose the preferred OSPF path.

39. show ip ospf neighbor.

40. show ip ospf neighbor, show ip ospf interface, show ip route ospf, and show ip protocols.

Static & Default Routing

41. A manually configured route to a destination network.

42. A route such as 0.0.0.0/0 used when no specific route matches.

43. A backup static route configured with a higher administrative distance.

44. It identifies the next Layer 3 device to which the router should forward traffic.

45. The next hop may be unreachable, the outgoing interface may be down, or the route may not be valid.

46. The router resolves a configured next hop to determine the actual outgoing interface.

47. Use `show ip route` and `show running-config` to inspect the route configuration.

48. Combining multiple contiguous networks into a less-specific prefix.

49. Traffic often requires a valid reverse path for successful bidirectional communication.

50. Check interfaces, routing table, next hop, route selection, ACLs, and the return path.

HSRP & FHRP

51. Hot Standby Router Protocol provides a virtual default gateway for hosts.

52. First Hop Redundancy Protocol; a category of protocols that provide redundant default gateways.

53. The router currently forwarding traffic for the HSRP virtual IP.

54. The router ready to take over if the active router fails.

55. Hosts keep the same default gateway address while the forwarding router can change.

56. By configuring priority and, when desired, preemption.

57. It allows a higher-priority router to reclaim the active role after recovering.

58. Layer 2 connectivity, VLAN, HSRP version, group, authentication, timers, and interface state.

59. show standby.

60. Verify VLAN reachability, compare HSRP parameters, inspect active/standby state, and test the virtual gateway.

NAT & ACLs

61. Create an access-list or named ACL with permit/deny statements and apply it in the correct direction and interface.

62. Closer to the destination, because it filters primarily by source address.

63. Closer to the source, because it can match source, destination, protocol, and ports.

64. An unmatched packet is denied after the explicit rules.

65. It may be applied to the wrong interface or direction, have an incorrect sequence/order, or lack a return-traffic rule.

66. Use show access-lists and inspect the interface configuration and counters.

67. PAT: many inside hosts share one public address using translated ports.

68. Use show ip nat translations and show ip nat statistics.

69. Inside/outside interface roles, matching rules, routing, and the traffic flow.

70. Check rule order, match criteria, interface/direction, counters, and both forward and return traffic.

Layer 3 Switching

71. A Switched Virtual Interface that provides a Layer 3 interface for a VLAN.

72. Routing between VLANs using SVIs on a Layer 3 switch.

73. ip routing in global configuration mode.

74. The VLAN may not exist, may have no active member ports, or the SVI/interface may be administratively disabled.

75. A physical switch interface operating as a Layer 3 routed interface instead of a Layer 2 switchport.

76. Use no switchport under the interface.

77. An SVI represents a VLAN; a routed port is a physical Layer 3 interface.

78. Use show ip interface brief and show interfaces vlan <id>.

79. Incorrect VLAN assignment, SVI addressing, ip routing state, trunking, or ACL configuration.

80. Verify VLANs, trunks, SVIs, routing state, routes, ACLs, and endpoint gateways.

Cisco Security

81. Unused ports can provide unnecessary access and increase attack surface.

82. A Layer 2 feature that restricts which MAC addresses may use a switch port.

- 83.** A security feature that identifies trusted DHCP server ports and helps block rogue DHCP responses.
- 84.** A feature that validates ARP messages using trusted bindings to reduce ARP spoofing attacks.
- 85.** A feature that helps prevent source-address spoofing using DHCP snooping bindings.
- 86.** It protects edge ports by reacting when unexpected BPDUs are received.
- 87.** SSH encrypts management traffic; Telnet sends credentials and data in clear text.
- 88.** Authentication, Authorization, and Accounting.
- 89.** Use SSH, strong authentication, least privilege, management ACLs, logging, and disable unnecessary services.
- 90.** Use multiple controls such as segmentation, port security, DHCP snooping, DAI, secure management, and monitoring.

CCNA Troubleshooting

- 91.** Physical link, VLAN assignment, switchport state, ARP, gateway SVI, and local addressing.
- 92.** Allowed VLAN list, native VLAN, VLAN existence, tagging, and both ends of the trunk.
- 93.** MTU mismatch is a common cause, along with other adjacency parameters.
- 94.** Route presence, next-hop reachability, return route, ACLs, and the actual destination.

- 95.** Layer 2 segmentation, HSRP group/version mismatch, or parameters that prevent proper peer communication.
- 96.** Speed/duplex, trunk/access parameters, channel protocol, and member configuration.
- 97.** DHCP reachability, VLAN/trunk path, DHCP server/scope, relay, and client configuration.
- 98.** Layer 1 is detected but the Layer 2 protocol is not operational, often due to encapsulation or link issues.
- 99.** show ip interface brief.
- 100.** State the symptom, identify the likely layer, name the verification commands, make one controlled change, and verify the fix.

CEH

100 Questions

Reconnaissance & Scope

- 201. What is reconnaissance in ethical hacking?
- 202. Why is authorization important before security testing?
- 203. What is passive reconnaissance?
- 204. What is active reconnaissance?
- 205. What is OSINT?
- 206. What is attack surface?
- 207. What is a scope document?
- 208. Why should findings be validated?
- 209. What is the difference between a vulnerability and an exploit?
- 210. What is responsible reporting?

Scanning & Enumeration

- 211. What is host discovery?
- 212. What is port scanning?
- 213. What is service enumeration?
- 214. Why can scan results be incomplete?
- 215. What is banner grabbing?
- 216. Why should scanners be used carefully in production?
- 217. What is a false positive in vulnerability scanning?
- 218. What is a false negative?
- 219. What is enumeration?
- 220. How should a pentester validate a high-risk scanner finding?

Web Security

- 221. What is SQL injection?
- 222. What is XSS?
- 223. What is CSRF?

- 224. What is command injection?
- 225. What is directory traversal?
- 226. Why is input validation important?
- 227. Why are parameterized queries effective against SQL injection?
- 228. What is secure session management?
- 229. What is an IDOR/BOLA issue?
- 230. How should a web finding be reported?

Phishing & Social Engineering

- 231. What is phishing?
- 232. What is spear phishing?
- 233. What is whaling?
- 234. What is business email compromise?
- 235. What indicators can reveal a phishing email?
- 236. Why can MFA reduce phishing impact?
- 237. What is pretexting?
- 238. What is baiting?
- 239. How should an organization respond to a suspected phishing campaign?
- 240. What is security awareness training supposed to achieve?

Credential Security

- 241. Why are passwords hashed?
- 242. Why should passwords be salted?
- 243. What is password spraying?
- 244. What is credential stuffing?
- 245. What is brute force?
- 246. Why is MFA important?
- 247. What is least privilege?
- 248. What is account lockout and what is its trade-off?
- 249. What should defenders monitor for credential attacks?

250. What is a credential exposure response?

Cryptography

251. What is symmetric encryption?

252. What is asymmetric cryptography?

253. What is hashing?

254. What is digital signing?

255. What is TLS used for?

256. Why is MD5 not recommended for security-critical integrity?

257. What is a certificate?

258. What is key rotation?

259. What is perfect forward secrecy?

260. What should a security analyst verify when investigating suspicious encrypted traffic?

Malware

261. What is malware?

262. What is a virus?

263. What is a worm?

264. What is a trojan?

265. What is ransomware?

266. What is a rootkit?

267. What is a botnet?

268. What is a dropper?

269. What is fileless malware?

270. How should suspicious malware be handled?

Network Attacks

271. What is ARP spoofing?

272. What is a man-in-the-middle attack?

273. What is DNS poisoning?

274. What is a SYN flood?

- 275. What is a DDoS attack?
- 276. What is session hijacking?
- 277. What is a rogue access point?
- 278. How can network segmentation reduce attack impact?
- 279. What telemetry helps investigate network attacks?
- 280. What is a safe approach to validating a suspected network attack?

Vulnerability Management

- 281. What is vulnerability management?
- 282. What is CVE?
- 283. What is CVSS?
- 284. Why should vulnerability priority not rely only on CVSS?
- 285. What is patch management?
- 286. What is a zero-day?
- 287. What is remediation validation?
- 288. What is compensating control?
- 289. Why is asset inventory important?
- 290. What should a vulnerability report contain?

Incident Response

- 291. What is incident response?
- 292. What is containment?
- 293. What is eradication?
- 294. What is recovery?
- 295. Why is evidence preservation important?
- 296. What is a timeline in incident response?
- 297. What is root-cause analysis?
- 298. When should an incident be escalated?
- 299. What should an incident report include?
- 300. What is a tabletop exercise?

Answer Key — CEH

Reconnaissance & Scope

1. The information-gathering phase used to understand the authorized target and attack surface.
2. Testing without explicit permission can be illegal, disruptive, and outside the agreed scope.
3. Collecting information without directly interacting with the target systems.
4. Interacting with target infrastructure to gather information, such as querying services or scanning hosts.
5. Open-Source Intelligence gathered from publicly available sources.
6. The set of exposed assets, services, interfaces, identities, and technologies that could be targeted.
7. A document defining authorized targets, methods, timing, exclusions, and rules of engagement.
8. To reduce false positives and ensure the reported issue is real and relevant.
9. A vulnerability is a weakness; an exploit is a technique or code used to take advantage of it.
10. Documenting evidence, impact, risk, reproduction details, and practical remediation within the agreed engagement process.

Scanning & Enumeration

11. Determining which hosts are reachable or active within an authorized scope.
12. Checking TCP/UDP ports to identify potentially accessible services.

- 13.** Identifying the service, version, configuration, or other details associated with an exposed port.
- 14.** Firewalls, IDS/IPS, rate limiting, filtering, packet loss, or service behavior can affect visibility.
- 15.** Collecting service information from banners or protocol responses.
- 16.** Aggressive scanning can create load, trigger controls, or disrupt fragile systems.
- 17.** A reported issue that is not actually present or not exploitable in the tested context.
- 18.** A real issue that the scanner fails to detect.
- 19.** Extracting detailed information about users, shares, services, protocols, or systems after initial discovery.
- 20.** Confirm the affected asset, reproduce safely within scope, collect evidence, and assess actual impact.

Web Security

- 21.** An injection flaw where untrusted input changes the intended structure of a database query.
- 22.** Cross-Site Scripting, where attacker-controlled script content is executed in a victim's browser context.
- 23.** Cross-Site Request Forgery, where a victim's browser is induced to send an unwanted authenticated request.
- 24.** A flaw that allows untrusted input to influence operating-system command execution.
- 25.** Manipulating file path input to access files outside the intended directory.

- 26.** It reduces the ability of untrusted data to alter application behavior unexpectedly.
- 27.** They separate SQL code from user-supplied data.
- 28.** Protecting session identifiers, enforcing expiration, secure cookie attributes, and preventing session fixation or theft.
- 29.** Improper authorization that allows a user to access another object's data by changing an identifier.
- 30.** Include affected endpoint, evidence, security impact, severity, safe reproduction steps, and remediation.

Phishing & Social Engineering

- 31.** A social-engineering technique that uses deceptive messages to obtain information, access, or actions.
- 32.** A targeted phishing campaign aimed at a specific person or organization.
- 33.** Targeted social engineering against senior or high-value individuals.
- 34.** Abuse of email or identity to impersonate trusted parties and cause fraud or unauthorized actions.
- 35.** Unexpected requests, suspicious domains, mismatched links, unusual urgency, attachments, or authentication anomalies.
- 36.** A second factor can prevent password-only compromise, although phishing-resistant MFA is stronger against adversary-in-the-middle attacks.
- 37.** Creating a believable story or false identity to persuade a target to disclose information or perform an action.

38. Using an enticing offer or object to persuade a victim to interact with malicious content.

39. Contain affected accounts/messages, preserve evidence, investigate indicators, notify users, and improve controls.

40. It helps users recognize threats, follow reporting procedures, and reduce risky behavior.

Credential Security

41. A secure password hash stores a one-way representation rather than the original password.

42. A unique salt reduces the effectiveness of precomputed tables and identical-hash comparisons.

43. Trying a small number of common passwords across many accounts to avoid triggering lockouts.

44. Using previously leaked username/password pairs against other services.

45. Systematically trying many password or key combinations until a valid credential is found.

46. It adds another authentication factor so a stolen password alone is less useful.

47. Users and processes receive only the access necessary for their tasks.

48. It limits repeated authentication attempts but can also enable denial-of-service through intentional lockouts.

49. Failed logins, unusual sources, impossible travel, password spraying patterns, MFA anomalies, and account changes.

50. Reset affected credentials, investigate use, revoke sessions/tokens as needed, identify the source, and improve controls.

Cryptography

51. Encryption using the same secret key for encryption and decryption.

52. Cryptography using a public/private key pair.

53. A one-way transformation used for integrity, indexing, password storage, and other purposes.

54. Using a private key to create a signature that can be verified with the corresponding public key.

55. Protecting application communication in transit using authentication, encryption, and integrity mechanisms.

56. It has practical collision weaknesses and is unsuitable for modern security uses.

57. A digitally signed document binding an identity to a public key.

58. Replacing cryptographic keys periodically or when risk or policy requires it.

59. A property where compromise of a long-term key does not reveal past session keys.

60. Endpoints, timing, destinations, certificates, process context, DNS, and other metadata rather than assuming encryption means malicious activity.

Malware

61. Malicious software designed to disrupt, damage, spy on, or gain unauthorized access to systems.

62. Malware that typically attaches to another file or program and spreads when the host is executed.

63. Malware capable of self-propagation across systems or networks without requiring a host file in the same way as a virus.

64. Malicious software disguised as legitimate or useful software.

65. Malware that typically encrypts or otherwise blocks access to data and demands payment.

66. Malware designed to hide malicious activity or maintain privileged persistence.

67. A collection of compromised devices controlled by an operator or command-and-control infrastructure.

68. A program or component that delivers or installs another malicious payload.

69. Malicious activity that relies heavily on memory, scripts, legitimate tools, or other techniques rather than a traditional executable file.

70. Isolate safely, preserve evidence, analyze in an appropriate environment, identify scope, eradicate persistence, and recover according to procedure.

Network Attacks

71. Sending forged ARP information to associate an attacker's MAC address with another IP address.

72. An attacker positions themselves between communicating parties to observe or alter traffic.

73. Providing or inserting false DNS information so users resolve a name to an unintended address.

- 74.** A denial-of-service technique that sends many TCP SYN requests and consumes connection resources.
- 75.** A distributed denial-of-service attack using multiple sources to overwhelm a target.
- 76.** Taking over an authenticated session by obtaining or abusing its session identifier.
- 77.** An unauthorized wireless access point connected to or impersonating a trusted network.
- 78.** It limits lateral movement and restricts which systems can directly communicate.
- 79.** Firewall logs, DNS, proxy logs, NetFlow/flow data, packet captures, IDS alerts, and endpoint telemetry.
- 80.** Confirm the indicator, identify scope, collect evidence, and test controls only within authorized boundaries.

Vulnerability Management

- 81.** The ongoing process of identifying, prioritizing, remediating, and validating security weaknesses.
- 82.** A standardized identifier for a publicly disclosed vulnerability.
- 83.** A framework and scoring system used to communicate vulnerability severity.
- 84.** Business impact, exploit availability, exposure, asset criticality, and compensating controls also matter.
- 85.** The controlled process of testing, deploying, and verifying software updates.

86. A vulnerability or attack for which defenders may have little or no prior opportunity to patch before exploitation becomes known or occurs.

87. Checking that the vulnerability is actually fixed and the control works as intended.

88. An alternative security measure that reduces risk when the primary fix cannot yet be applied.

89. You cannot reliably secure systems you do not know exist or do not understand.

90. Affected asset, vulnerability, evidence, severity, business impact, remediation, owner, and validation status.

Incident Response

91. A structured process for detecting, containing, investigating, eradicating, and recovering from security incidents.

92. Actions taken to limit an incident's spread or impact.

93. Removing the cause, malware, persistence, or unauthorized access associated with the incident.

94. Restoring systems and operations to a secure and trusted state.

95. It supports investigation, root-cause analysis, lessons learned, and potentially legal or compliance requirements.

96. A chronological reconstruction of relevant events and actions.

97. Determining why the incident occurred and how the attacker or failure succeeded.

98. When severity, scope, business impact, regulatory requirements, or uncertainty exceeds the analyst's authority or capability.

99. Summary, timeline, scope, evidence, impact, root cause, actions, and recommendations.

100. A discussion-based exercise used to test incident-response plans and decision making.

LPIC-1

100 Questions

Linux CLI

- 301. What does pwd do?
- 302. What does ls do?
- 303. What does cd do?
- 304. What does cp do?
- 305. What does mv do?
- 306. What does rm do?
- 307. What does mkdir do?
- 308. What does cat do?
- 309. What does less provide?
- 310. Why are command options important in Linux?

Permissions & Ownership

- 311. What are the three basic Linux permission classes?
- 312. What do r, w, and x mean for a regular file?
- 313. What does chmod change?
- 314. What does chown change?
- 315. What does chgrp change?
- 316. What does 755 mean?
- 317. What does 644 mean?
- 318. What is umask?
- 319. What is setuid?
- 320. Why is least privilege important on Linux?

Processes

- 321. What is a process?
- 322. What does ps show?
- 323. What does top provide?

- 324. What does kill do?
- 325. What is SIGTERM?
- 326. What is SIGKILL?
- 327. What is a zombie process?
- 328. What is load average?
- 329. How do you find a process by name?
- 330. How should you troubleshoot a high-CPU process?

systemd & Services

- 331. What is systemd?
- 332. What does systemctl status do?
- 333. What does systemctl start do?
- 334. What does systemctl stop do?
- 335. What does systemctl restart do?
- 336. What does systemctl enable do?
- 337. What does systemctl disable do?
- 338. What is journalctl?
- 339. How do you troubleshoot a failed service?
- 340. Why is service verification important after a change?

Linux Networking

- 341. Which command commonly displays IP addresses on modern Linux?
- 342. Which command shows the routing table?
- 343. What does ping test?
- 344. What does ss show?
- 345. What does ip neigh show?
- 346. What is the default gateway?
- 347. What is a DNS resolver?
- 348. How do you test DNS resolution?
- 349. What should you check if Linux cannot reach the internet?
- 350. How can you inspect listening services?

SSH

- 351. What is SSH?
- 352. What is the default SSH server port?
- 353. What is public-key authentication?
- 354. Where is a user's authorized public key commonly stored?
- 355. Why is key-based authentication useful?
- 356. What should you check if SSH connection is refused?
- 357. What does sshd_config control?
- 358. Why should root SSH access be restricted?
- 359. What is SSH tunneling?
- 360. How do you troubleshoot an SSH login failure?

Package Management

- 361. What is a package manager?
- 362. What package manager is common on Debian-based systems?
- 363. What package manager is common on RPM-based systems?
- 364. What does apt update do?
- 365. What does apt upgrade do?
- 366. What is a repository?
- 367. Why are package signatures important?
- 368. What is a dependency?
- 369. How should package changes be handled on production systems?
- 370. What should you do if a package installation fails?

Storage

- 371. What does df show?
- 372. What does du show?
- 373. What is an inode?
- 374. Why can a filesystem have free space but still fail to create files?
- 375. What is mount?
- 376. What is /etc/fstab?

- 377. What is LVM?
- 378. What is swap?
- 379. How do you find large files or directories?
- 380. How do you troubleshoot a full filesystem?

Users, Groups & sudo

- 381. What is /etc/passwd?
- 382. What is /etc/shadow?
- 383. What is a UID?
- 384. What is a GID?
- 385. What does useradd do?
- 386. What does passwd do?
- 387. What is sudo?
- 388. Why should sudo rules follow least privilege?
- 389. What is the purpose of groups?
- 390. How would you investigate an unexpected privileged action?

Automation & Troubleshooting

- 391. What is a shell script?
- 392. What is a shebang?
- 393. Why use variables in shell scripts?
- 394. What is exit status in Linux?
- 395. What does && do in a shell command line?
- 396. What does | do?
- 397. What does grep do?
- 398. What does awk commonly help with?
- 399. What is cron?
- 400. How should you troubleshoot a failing automation script?

Answer Key — LPIC-1

Linux CLI

1. It prints the current working directory.
2. It lists directory contents.
3. It changes the current working directory.
4. It copies files or directories.
5. It moves or renames files or directories.
6. It removes files or directories; recursive deletion should be used carefully.
7. It creates directories.
8. It displays or concatenates file contents.
9. Interactive viewing of text with search and navigation.
10. They modify command behavior and allow precise administration and troubleshooting.

Permissions & Ownership

11. User/owner, group, and others.
12. Read, write, and execute.
13. File or directory permission bits.
14. File or directory ownership.
15. The group ownership of a file or directory.
16. Owner has rwx; group and others have r-x.
17. Owner has rw-; group and others have r--.

18. A value that removes default permission bits when new files and directories are created.

19. A permission bit that can cause an executable to run with the file owner's effective privileges.

20. It reduces the damage possible if an account or process is compromised.

Processes

21. A running instance of a program with its own execution context and resources.

22. Process information such as PID, state, CPU, memory, and command depending on options.

23. A live view of processes and system resource usage.

24. It sends a signal to a process.

25. A polite termination request that allows a process to clean up.

26. A forceful termination signal that cannot be caught or ignored by the target process.

27. A terminated child whose parent has not yet collected its exit status.

28. A measure representing runnable or uninterruptible task pressure over time intervals.

29. Commands such as pgrep, pidof, ps with filtering, or appropriate process tools can be used.

30. Identify the process, inspect CPU behavior, check logs and recent changes, and determine whether the load is expected or abnormal.

systemd & Services

- 31.** A common Linux init and service-management system.
- 32.** It shows the state and recent information for a service or unit.
- 33.** It starts a service or unit immediately.
- 34.** It stops a service or unit.
- 35.** It stops and starts a service, usually applying configuration changes.
- 36.** It configures a unit to start automatically according to its boot target.
- 37.** It removes the unit's automatic enablement.
- 38.** A command for querying the systemd journal.
- 39.** Check systemctl status, journalctl, configuration files, dependencies, ports, permissions, and recent changes.
- 40.** A command succeeding does not guarantee that the application is healthy or reachable.

Linux Networking

- 41.** ip addr or ip address.
- 42.** ip route.
- 43.** IP reachability and ICMP response.
- 44.** Socket and connection information.
- 45.** Neighbor/ARP-related information for local Layer 2/3 resolution.
- 46.** The router used to reach destinations outside the local subnet.
- 47.** A service or configuration used to resolve names into addresses and other DNS records.
- 48.** Use tools such as dig, host, or nslookup.

49. Interface state, IP/mask, route, gateway, DNS, firewall, and upstream connectivity.

50. Use `ss -lntup` or equivalent commands with appropriate privileges.

SSH

51. Secure Shell, an encrypted protocol for remote administration and other secure communications.

52. TCP 22 by default.

53. Authentication using a private key held by the client and a corresponding public key configured on the server.

54. In `~/.ssh/authorized_keys`.

55. It can be stronger and easier to automate securely than reusable passwords when managed properly.

56. Server service state, listening port, firewall, IP reachability, and `sshd` configuration.

57. Configuration of the OpenSSH server.

58. Direct privileged remote access increases risk and weakens accountability.

59. Using SSH connections to securely forward traffic between endpoints.

60. Check network reachability, port access, server logs, authentication method, permissions, account state, and configuration.

Package Management

61. A tool that installs, updates, removes, and tracks software packages and dependencies.

62. APT, with `dpkg` providing lower-level package handling.

- 63.** DNF is common on modern Fedora/RHEL-family systems; rpm provides lower-level package operations.
- 64.** It refreshes package repository metadata.
- 65.** It upgrades installed packages according to available repository updates.
- 66.** A source from which packages and metadata can be obtained.
- 67.** They help verify package authenticity and integrity.
- 68.** Software required by another package or application to function.
- 69.** Use approved repositories, change control, testing, backups where appropriate, and verification.
- 70.** Read the error, check repositories, dependencies, disk space, locks, architecture, and package state.

Storage

- 71.** Filesystem space usage and available capacity.
- 72.** Disk usage by files and directories.
- 73.** A filesystem data structure that stores metadata about a file or directory.
- 74.** It may have exhausted available inodes or hit another resource limit.
- 75.** Attaching a filesystem to a directory in the Linux filesystem hierarchy.
- 76.** A configuration file describing filesystems and mount options that can be used at boot.
- 77.** Logical Volume Manager, which provides flexible storage management using physical volumes, volume groups, and logical volumes.

78. Disk-backed space used to extend virtual memory when RAM pressure occurs.

79. Use tools such as `du`, `find`, `ncdu` where available, and appropriate sorting/filtering.

80. Check `df`, locate high-usage paths with `du/find`, inspect logs, temporary files, deleted-open files, and inode usage.

Users, Groups & sudo

81. A file containing local account information such as usernames, UIDs, home directories, and login shells.

82. A protected file containing password-related hashes and aging information on typical Linux systems.

83. A numeric user identifier.

84. A numeric group identifier.

85. It creates a user account according to specified options and system defaults.

86. It changes a user's password and can manage password-related settings.

87. A mechanism allowing authorized users to execute commands with another user's privileges, commonly root.

88. Users should receive only the administrative commands they actually need.

89. They provide a convenient way to assign shared permissions to multiple users.

90. Review `sudo` logs, authentication logs, account/group membership, command history where appropriate, and system audit data.

Automation & Troubleshooting

- 91.** A text file containing commands and control logic executed by a shell.
- 92.** The first line that specifies the interpreter used to execute a script.
- 93.** They make scripts reusable and allow data to be passed between commands.
- 94.** A numeric result returned by a command; zero conventionally means success.
- 95.** It runs the next command only if the previous command succeeds.
- 96.** It sends standard output from one command to another command's standard input.
- 97.** It searches text for lines matching a pattern.
- 98.** Text processing, field extraction, and simple data transformation.
- 99.** A scheduler used to run commands or scripts at specified times or intervals.
- 100.** Check interpreter, permissions, environment variables, paths, exit codes, logs, assumptions, and run it safely with tracing when appropriate.

SOC Analysis

100 Questions

Alert Triage

- 401. What is SOC alert triage?
- 402. What is a false positive?
- 403. What is alert severity?
- 404. What is alert confidence?
- 405. What context should an analyst collect?
- 406. Why is asset criticality important?
- 407. What is alert enrichment?
- 408. What is alert correlation?
- 409. When should an alert be escalated?
- 410. What should a good triage note contain?

SIEM

- 411. What is a SIEM?
- 412. What is log normalization?
- 413. What is a correlation rule?
- 414. Why is time synchronization important in SIEM?
- 415. What is a data source?
- 416. What can cause missing logs?
- 417. What is a detection query?
- 418. Why should detections be tuned?
- 419. What should you check when a SIEM alert suddenly stops firing?
- 420. How do you investigate a suspicious SIEM alert?

MITRE ATT&CK

- 421. What is MITRE ATT&CK?
- 422. What is a tactic?
- 423. What is a technique?

- 424. Why do SOC teams use ATT&CK?
- 425. What is detection coverage?
- 426. Why is ATT&CK mapping not proof of compromise?
- 427. How can ATT&CK support threat hunting?
- 428. What is a sub-technique?
- 429. How can a SOC measure gaps using ATT&CK?
- 430. How should an ATT&CK finding be documented?

EDR & Endpoint Analysis

- 431. What is EDR?
- 432. What is a process tree?
- 433. Why is command-line data valuable?
- 434. What endpoint fields are commonly useful?
- 435. What is endpoint isolation?
- 436. What is persistence?
- 437. Why can legitimate tools generate EDR alerts?
- 438. What is process injection?
- 439. How do you investigate a suspicious endpoint alert?
- 440. What should be verified before isolating a critical endpoint?

Phishing Investigation

- 441. What should an analyst inspect in a suspicious email?
- 442. What is a URL reputation check?
- 443. Why are redirects important in phishing analysis?
- 444. What is an email authentication result?
- 445. What should you do with a suspicious attachment?
- 446. How do you scope a phishing campaign?
- 447. What is credential phishing?
- 448. How can you identify affected users?
- 449. What is a good containment action for malicious email?
- 450. What should the final phishing investigation include?

Windows Event Analysis

- 451. Why are Windows security logs important to a SOC?
- 452. What does a successful logon event help establish?
- 453. What can repeated failed logons indicate?
- 454. Why is logon type useful?
- 455. What is account lockout telemetry useful for?
- 456. Why is time synchronization important on Windows hosts?
- 457. What should you correlate with a suspicious Windows logon?
- 458. What is privilege escalation?
- 459. How can PowerShell activity be investigated?
- 460. How should an analyst avoid overreacting to a single Windows event?

Network Detection

- 461. What is network telemetry?
- 462. What is beaconing?
- 463. Why is DNS valuable to a SOC?
- 464. What is rare-domain activity?
- 465. What is C2?
- 466. What should be correlated with a suspicious outbound connection?
- 467. Why can encrypted traffic still be investigated?
- 468. What is data exfiltration?
- 469. What network signs can suggest exfiltration?
- 470. How do you validate a suspected C2 connection?

Incident Response

- 471. What is the difference between containment and recovery?
- 472. When should an endpoint be isolated?
- 473. Why preserve evidence before making changes?
- 474. What is an incident timeline?
- 475. What is root-cause analysis?

- 476. What is scope determination?
- 477. What is eradication?
- 478. What is post-incident review?
- 479. Why are response playbooks useful?
- 480. What makes a strong incident report?

Threat Hunting

- 481. What is threat hunting?
- 482. How does threat hunting differ from alert triage?
- 483. Give an example of a threat-hunting hypothesis.
- 484. Why is baselining useful in threat hunting?
- 485. What telemetry can support hunting?
- 486. What is a hunting query?
- 487. What should happen after a successful hunt?
- 488. How can threat hunters reduce false positives?
- 489. Why is hypothesis quality important?
- 490. How should hunting results be communicated?

SOC Interview Skills

- 491. How should you answer a SOC interview scenario?
- 492. What is more important than memorizing tools?
- 493. How do you explain a false positive professionally?
- 494. How do you prioritize multiple alerts?
- 495. What should you do if you do not know the answer?
- 496. What makes good SOC documentation?
- 497. Why is escalation important in a SOC?
- 498. What is a good first response to a critical alert?
- 499. How do you demonstrate troubleshooting ability in an interview?
- 500. What mindset should a SOC analyst have?

Answer Key — SOC Analysis

Alert Triage

1. The process of validating an alert, assessing severity, gathering context, and deciding the next action.
2. An alert triggered by benign activity that does not represent a real security incident.
3. An assessment of the potential impact or urgency of the detected activity.
4. How strongly the available evidence supports the detection being malicious or suspicious.
5. User, host, asset criticality, time, process, network activity, related alerts, and business context.
6. The same event can have very different risk depending on the affected system.
7. Adding useful context such as threat intelligence, identity, asset, process, or historical information.
8. Linking related events across data sources to understand a larger activity pattern.
9. When evidence, severity, scope, or required response exceeds the analyst's authority or capability.
10. Observed evidence, scope, reasoning, actions, disposition, and escalation or closure rationale.

SIEM

11. A Security Information and Event Management platform that collects, normalizes, correlates, searches, and alerts on security data.

- 12.** Converting different log formats into a consistent structure for searching and correlation.
- 13.** Logic that combines events or conditions to identify suspicious patterns.
- 14.** Accurate timestamps are essential for correlation and incident timelines.
- 15.** A system or service that sends telemetry or logs into the SIEM.
- 16.** Agent failure, network issues, parser problems, storage limits, configuration changes, or source outages.
- 17.** A search or logic expression designed to identify suspicious activity in collected data.
- 18.** To reduce noise and false positives while preserving useful detection coverage.
- 19.** Data-source health, ingestion, parsing, query logic, rule status, time ranges, and recent changes.
- 20.** Validate the detection, enrich context, correlate related events, scope affected assets/users, and determine response.

MITRE ATT&CK

- 21.** A knowledge base describing adversary tactics and techniques based on observed behavior.
- 22.** The adversary's high-level objective, such as Credential Access or Persistence.
- 23.** A method used to achieve a tactical objective.
- 24.** It helps structure detections, threat hunting, reporting, and coverage analysis.

- 25.** The degree to which relevant adversary behaviors can be detected with available telemetry and analytics.
- 26.** A behavior may be legitimate; mapping describes technique alignment, while incident confirmation requires independent evidence.
- 27.** Analysts can build hypotheses around known techniques and search telemetry for related behavior.
- 28.** A more specific behavior grouped under a broader ATT&CK technique.
- 29.** Map existing detections and telemetry to techniques and identify important uncovered behaviors.
- 30.** Record the technique, evidence, affected assets, detection logic, confidence, and recommended improvements.

EDR & Endpoint Analysis

- 31.** Endpoint Detection and Response, which collects endpoint telemetry and supports detection, investigation, and response.
- 32.** A parent-child view of process execution that helps reveal suspicious process relationships.
- 33.** It can reveal the exact commands and parameters used by a process.
- 34.** Process, parent process, user, command line, hash, path, host, network connection, and timestamp.
- 35.** A response action that restricts a host's network communication to contain a threat.
- 36.** A mechanism that allows malicious or unwanted software to remain active after reboot or logon.
- 37.** Attackers often abuse legitimate administrative tools, creating behavior that overlaps with normal operations.

38. A technique where code or execution is introduced into another process context.

39. Review the process tree, command line, user, file, hash, network connections, persistence, and related events.

40. Confirm the evidence and impact, follow the incident playbook, and consider business continuity and escalation requirements.

Phishing Investigation

41. Sender identity, headers, URLs, attachments, authentication results, recipients, timing, and message context.

42. An assessment of whether a domain or URL is associated with known malicious or suspicious activity.

43. The visible URL may lead through multiple destinations before reaching the final site.

44. Signals such as SPF, DKIM, and DMARC help assess whether a message is authorized and authentic.

45. Do not open it on a normal workstation; analyze safely using approved security tooling and preserve evidence.

46. Search for the same sender, subject, URLs, hashes, message IDs, and related indicators across recipients and systems.

47. Phishing designed to trick users into entering credentials into a fraudulent site or workflow.

48. Correlate message delivery, clicks, authentication events, endpoint telemetry, and user reports.

49. Remove or quarantine matching messages and block malicious indicators according to policy.

50. Indicators, affected users, timeline, evidence, containment, impact, and recommendations.

Windows Event Analysis

51. They provide evidence about authentication, process-related activity, policy changes, and other security events.

52. Which account authenticated, when, and from relevant source context depending on the event and logging configuration.

53. Password attacks, misconfiguration, stale credentials, or other authentication problems.

54. It provides context about how authentication occurred, such as interactive or network-related access.

55. Identifying repeated authentication failures and possible password attacks.

56. Accurate timestamps support event correlation and incident timelines.

57. Source IP, user, host, process, privilege changes, network activity, and neighboring events.

58. Gaining higher permissions than originally authorized.

59. Review command-line/script logging, parent process, user, encoded content, network activity, and related endpoint telemetry.

60. Treat it as a signal, add context, correlate related activity, and assess whether the behavior is expected.

Network Detection

61. Data describing network communications, such as flows, DNS, firewall logs, proxy records, or packet captures.

- 62.** Repeated communications at relatively regular intervals that may indicate command-and-control behavior.
- 63.** It provides visibility into domains contacted by systems and can reveal suspicious resolution patterns.
- 64.** Communication with a domain rarely or never seen elsewhere in the environment, which may warrant investigation.
- 65.** Command and Control infrastructure used by an attacker to communicate with compromised systems.
- 66.** Host, user, process, destination, DNS, timing, volume, protocol, and threat intelligence.
- 67.** Metadata such as endpoints, timing, certificates, DNS, process context, and flow patterns remain visible.
- 68.** Unauthorized transfer of data out of an environment.
- 69.** Unusual destinations, volume changes, rare protocols, abnormal transfer times, or unexpected data flows.
- 70.** Correlate network indicators with endpoint process activity, DNS, reputation, timing, and known organizational behavior.

Incident Response

- 71.** Containment limits the incident; recovery restores systems to a secure operational state.
- 72.** When evidence indicates compromise and isolation is appropriate under the incident-response playbook.
- 73.** Changes can destroy or alter useful forensic information.
- 74.** A chronological sequence of relevant events, observations, and response actions.

- 75.** Determining the underlying reason and attack path that allowed the incident to occur.
- 76.** Identifying all affected users, hosts, accounts, data, and time periods.
- 77.** Removing malicious artifacts, persistence, unauthorized access, and the underlying cause.
- 78.** A review of what happened, what worked, what failed, and what should be improved.
- 79.** They provide repeatable steps, decision points, ownership, and escalation guidance.
- 80.** Clear scope, timeline, evidence, impact, root cause, response actions, and recommendations.

Threat Hunting

- 81.** Proactive, hypothesis-driven searching for suspicious activity that may not have triggered an alert.
- 82.** Triage starts from an alert; hunting starts from a hypothesis or behavior to discover previously unknown activity.
- 83.** Search for endpoints making periodic connections to rare domains while an unusual process is active.
- 84.** It helps distinguish normal organizational behavior from anomalies.
- 85.** EDR, DNS, authentication, network flow, proxy, firewall, cloud, and application logs.
- 86.** A query designed to test a hypothesis against available telemetry.
- 87.** Document findings, determine scope, improve detections, and record relevant indicators and techniques.

88. Use multiple signals, baselines, asset/user context, and validation before declaring malicious activity.

89. A clear hypothesis determines what data to query and how to interpret results.

90. State the hypothesis, data sources, findings, evidence, confidence, scope, and recommended actions.

SOC Interview Skills

91. Use a structured flow: validate the alert, gather evidence, scope it, assess risk, respond, document, and verify.

92. Analytical reasoning, evidence handling, prioritization, and understanding security fundamentals.

93. Show the evidence, explain why the activity is benign, document the reasoning, and suggest tuning if appropriate.

94. Consider severity, confidence, asset criticality, user impact, active-threat indicators, and business context.

95. State what you know, explain your investigation approach, identify the data you would collect, and avoid inventing facts.

96. Clear timestamps, evidence, scope, actions, reasoning, and final disposition.

97. It ensures incidents receive the right authority, expertise, and response resources.

98. Validate the alert quickly, gather high-value context, assess scope, and follow the approved response process.

99. Explain symptom, hypothesis, evidence, tools, controlled action, and verification.

100. Be curious, evidence-driven, skeptical of assumptions, methodical, and focused on reducing risk.